

PARA O ALTO E AVANTE

METODOLOGIAS DE RI



13

LISTA DE FIGURAS

Figura 1 – ITIL <i>versus</i> COBIT.....	5
Figura 2 – Definição do cenário: levantamento da topologia da instituição incluindo filiais	7
Figura 3 – Modelo de fluxo de tratamento de incidentes.....	18

EMANSP

LISTA DE QUADROS

Quadro 1 – Modelo de checklist	17
--------------------------------------	----

EMENDAS

SUMÁRIO

1 METODOLOGIAS	5
1.1 Introdução	5
2 PRINCIPAIS METODOLOGIAS	5
2.1 Aplicando a metodologia	6
2.2 Contexto: cenário e estudo de caso	6
2.2.1 Cenário	6
2.2.2 Estudo de caso	8
3 PROPÓSITO E ESCOPO	8
4 PAPÉIS E RESPONSABILIDADES	9
5 COMUNICAÇÃO	10
6 TIPOS DE INCIDENTE	11
6.1 Prioridades	11
6.2 Notificação de incidentes	12
7 ARMAZENAMENTO DE DOCUMENTOS E EVIDÊNCIAS	12
8 CHECKLISTS	13
9 FLUXO BÁSICO PARA TRATAMENTO DE INCIDENTES	18
CONCLUSÃO	19
REFERÊNCIAS	20

1 METODOLOGIAS

1.1 Introdução

Incidentes de segurança, a própria existência de vulnerabilidades e níveis de criticidade dos sistemas (mesmo que mínimos), são motivos suficientes para que sejam adotadas metodologias de governança, riscos e *compliance*. Essas metodologias garantem que sejam adotadas correções adequadas e tempestivas de incidentes utilizando, para isso, frameworks que orientam por meio do estudo de caso, e levando em consideração o cenário específico de aplicação, o mapeamento de processos que garantirão o correto gerenciamento de incidentes de TI.

Veremos, a partir de agora, algumas dessas metodologias, e como a utilização combinada de algumas metodologias pode ser saudável, complementando-se e auxiliando no desenvolvimento de uma melhor governança de TI.



Figura 1 – ITIL versus COBIT
Fonte: Elaborada pelo autor (2021)

2 PRINCIPAIS METODOLOGIAS

Quando o assunto é gestão de incidentes de segurança de TI, algumas metodologias se sobressaem, ora pela forma de abordagem, ora pela aplicabilidade. É o que acontece com a ITIL e a COBIT, por exemplo. Ambas são metodologias amplamente difundidas e aclamadas, que, em muitos aspectos, se complementam. Mas possuem um ponto comum: os benefícios para a instituição.

Seja qual for a metodologia escolhida, os pontos abordados a seguir são fundamentais nesse processo. Vamos discutir de forma ampla, sem nos atrelarmos a

nenhuma metodologia específica. Procure perceber a ideia principal por trás de cada etapa. Ao final, você perceberá quão parecidas todas essas metodologias são.

2.1 Aplicando a metodologia

No decorrer das últimas décadas, as instituições têm adotado amplamente a informatização em seus processos produtivos, e a internet potencializou esse processo. Essa evolução trouxe consigo problemas até então desconhecidos, os incidentes de segurança da informação, que têm obrigado os administradores a se atentarem quanto à segurança de seus aplicativos e serviços.

2.2 Contexto: cenário e estudo de caso

E como cada instituição é única, tem seus processos, produtos e públicos específicos, é preciso estudar previamente o cenário, aplicando estudos de caso e observando sempre as melhores práticas a serem adotadas para o tratamento de futuros incidentes.

2.2.1 Cenário

Essa etapa envolve uma série de levantamentos que serão úteis na elaboração do plano de tratamento de incidentes. São eles:

- Definir o público interno da instituição, agrupando em tipos (numa faculdade, por exemplo, podemos ter três tipos: alunos, professores, demais colaboradores);
- Definir, ainda, que tipo de atividade cada espécie de usuário realiza nos computadores, levando em consideração se o uso destes é compartilhado ou não;
- Definir que tipo de acesso cada usuário terá à internet ou aos sistemas internos, incluindo as permissões de cada um (se for o caso);

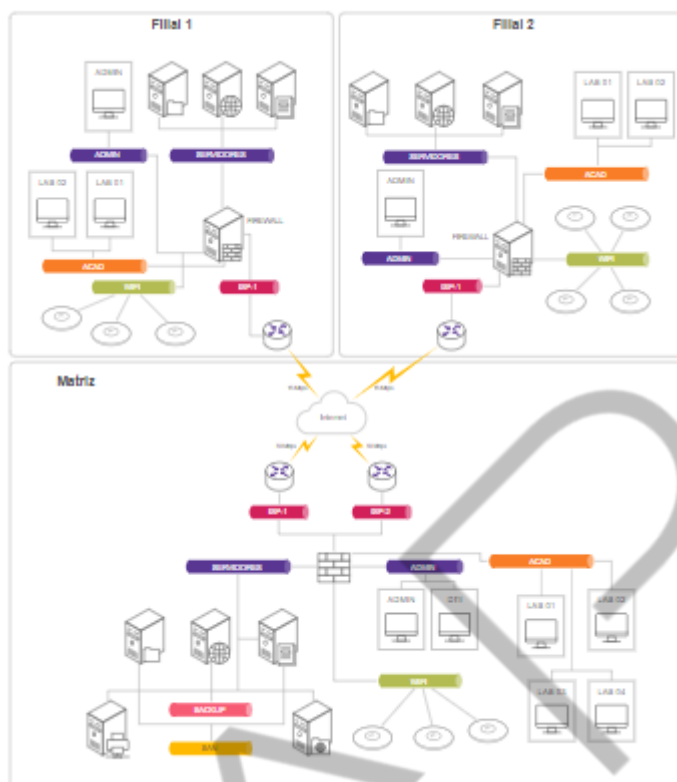


Figura 2 – Definição do cenário: levantamento da topologia da instituição incluindo filiais
Fonte: Adaptada pelo autor (2021)

- Fazer um levantamento do parque computacional, quantidade de computadores, pontos de acesso (inclusive sem fio), topologia de rede (Figura “Definição do cenário: levantamento da topologia da instituição incluindo filiais”) e disponibilidade de VPN (*Virtual Private Network*);
- Levantar qual tipo de autenticação será utilizada e como serão controlados os acessos, quais os níveis desse controle e como serão registrados, definindo, inclusive, uma trilha de auditoria para permitir o rastreo das informações em caso de incidente;
- Definir qual a escalabilidade provável da instituição, necessidades futuras e intenções de expansão; caso possua algum plano anterior de tratamento de incidentes, levá-lo em consideração.

2.2.2 Estudo de caso

Após a definição do cenário, faremos o estudo de caso, uma análise na qual descreveremos algumas informações importantes:

- Levantar registros de incidentes passados que não foram considerados incidentes por não haver ainda um plano de tratamento de incidentes;
- Realizar uma consulta aos funcionários da área de TI da instituição, que contribuirão para a definição do plano descrevendo os principais tipos de incidentes, papéis e responsabilidades de cada um durante o ciclo de vida do incidente, e as oportunidades de melhorias anteriormente observadas por eles.

Saiba mais: Essa etapa é muito importante no processo de elaboração do plano de tratamento de incidentes. Portanto, cabe ressaltar a importância da utilização de material de referência publicado por órgãos responsáveis por sua normatização, como o CERT.CC e o CERT.BR, disponíveis nos links abaixo:

<<https://www.cert.br/docs/>>;

<https://www.cert.br/certcc/csirts/csirt_faq-br.html>.

Recomendamos visitar os links e navegar em suas seções.

3 PROPÓSITO E ESCOPO

O propósito principal do plano de tratamento de incidentes é descrever os processos que serão utilizados para gerenciar e reportar os dados relacionados aos incidentes de segurança, tenham sido eles originados de fontes externas ou mesmo internas. As formas como serão reportados os incidentes observados por agentes internos (clientes e colaboradores) ou externos (comunidade e auditoria) também devem fazer parte do objetivo do plano.

Algumas situações podem envolver a necessidade de acionamento de autoridades policiais, sendo necessário, portanto, a coleta e o armazenamento das evidências, que poderão servir de provas em processos judiciais.

Com relação ao escopo, no plano, serão descritos papéis e responsabilidades, bem como o processo de tratamento do incidente propriamente dito a fim de garantir a resolução dos incidentes de segurança com agilidade, realizando a contenção e o restabelecimento dos serviços afetados.

4 PAPÉIS E RESPONSABILIDADES

Nessa etapa, definiremos os papéis e as responsabilidades de cada parte envolvida. São eles:

Comitê de Segurança e Risco

- Acionar a equipe de respostas a incidentes, envolvendo recursos externos, caso seja necessário, para a correta resolução.
- Coordenar a resolução dos incidentes.
- Comunicar o progresso da resposta a todos os envolvidos (externos e internos).
- Gerenciar todos os incidentes e as ações corretivas, bem como fazer a classificação destes.
- Fazer revisões pós-incidentes e gerar relatórios, apresentando-os ao Comitê de Segurança para discussão.
- Garantir que as melhorias necessárias sejam implementadas pelas equipes responsáveis.

Diretoria

- Aprovar as comunicações internas julgadas relevantes, notificando as instâncias superiores (se for o caso).
- Aprovar a utilização de recursos externos para a resolução de incidentes críticos.

Equipe de Resposta a Incidentes

- Reportar vulnerabilidades e incidentes conhecidos ao Comitê de Segurança e Risco sempre que necessário.

- Conduzir a resolução dos incidentes de segurança, utilizando, para isso, o fluxo de incidentes de TI, registrando sempre em alguma ferramenta de gerenciamento de *tickets*.
- Prover orientação e suporte para a detecção e resolução de incidentes de segurança.
- Executar as ações corretivas necessárias para a correta resolução do incidente de segurança.
- Reportar requisições importantes para mudanças, caso julgue necessária a alteração verificada.

5 COMUNICAÇÃO

Tão importante quanto a resposta ao incidente é a comunicação a todos os envolvidos (internos e externos) sobre o andamento dessa resposta. O Comitê de Segurança é que deve indicar quem deve ser notificado no decorrer do incidente e em seu encerramento, porém todas as notificações devem ser aprovadas pela Diretoria.

Nessa etapa de elaboração do plano, deve-se ter a devida atenção quanto à necessidade de comunicação de acordo com o ciclo de vida do incidente e a quais agentes essa notificação será enviada. Deve-se, novamente, levar em consideração o contexto e as especificidades da organização.

Nem todas as informações sobre o incidente devem ser dadas no início da resposta: a necessidade de confidencialidade pode ser uma premissa importante, e algumas evidências e detalhes técnicos devem ser divulgados apenas aos impactados ou envolvidos diretamente no incidente. Eventos de segurança de alta prioridade, por sua vez, podem ensejar a comunicação a agentes externos, por exemplo, empresas parceiras, agências governamentais e autoridades policiais, pois estes poderão prover (caso necessário) a assistência apropriada.

6 TIPOS DE INCIDENTE

Quanto aos tipos, devemos incluir no plano de tratamento de incidentes de segurança desde situações já ocorridas na organização até as improváveis (mas não impossíveis) de acontecer. De maneira geral, seguem linhas de raciocínio iniciais gerais, como as seguintes:

Incidente operacional: Falhas na integridade de informações, ou em sistemas, ocasionadas por alterações em configurações mal executadas ou mal planejadas.

Acidente: Falhas não intencionais, acidentais, em decorrência da inobservância às políticas de segurança da organização.

Uso inapropriado: Utilização inadequada para acesso a conteúdo inadequado ou que viole diretrizes internas ou, ainda, que coloque em risco a integridade da organização.

Furto ou roubo: Extravio não apenas de equipamentos e ativos, mas também de informações (sigilosas ou não) da organização.

Violação de acesso: Utilização não autorizada (incluindo mau uso de senhas e contas) de sistemas da organização com algum objetivo que viole suas políticas de segurança.

Incidente malicioso: Ataque intencional com o objetivo claro de causar perda, dano ou corrupção em informações e ativos de TI da organização. Esse tipo inclui, por exemplo, a desfiguração de sites, o sequestro de dados, inserção por injeção de códigos maliciosos ou vírus, entre outros.

6.1 Prioridades

Definir a prioridade é essencial, pois ditará o rito correcional do incidente, os envolvidos que deverão ser comunicados e as ações pós-correção do incidente. De maneira geral, podemos dividir as prioridades em baixa, média e alta, conforme descrito abaixo:

Baixa prioridade: Geralmente apropriada para incidentes com ações já mapeadas pela equipe de respostas, de fácil resolução ou baixo esforço operacional para resolução, de baixo ou nenhum impacto para os envolvidos, como tentativas de acesso não autorizadas e incidentes isolados de vírus.

Média prioridade: Apropriada para incidentes que precisam de coordenação e acompanhamento do Comitê de Segurança e Risco da organização, e envolvem brechas de falhas de segurança que requerem investigação e análise mais aprofundadas, como escaneamento de portas em redes (internas ou externas), múltiplos incidentes de vírus e acessos não autorizados.

Alta prioridade: Apropriada para incidentes que precisam ser escalados imediatamente à Diretoria e ao Comitê de Segurança, todos os envolvidos precisam ser notificados, inclusive, com uma revisão pós-encerramento do incidente. Envolvem eventos de impacto significativo a serviços críticos ou informações, danos a ativos ou a pessoas, como comprometimento de dados de pagamento, pichações ou *defaces* no site da organização, violações de dados sensíveis, financeiros ou pessoais, entre outros.

6.2 Notificação de incidentes

Essa etapa do plano de tratamento de incidentes deve indicar, de forma clara e objetiva, quais canais de atendimento serão oferecidos pela organização para o recebimento da notificação por qualquer usuário, interno ou externo (empresas parceiras ou clientes), e devem ser amplamente divulgados de modo a agilizar o acionamento do plano. Deve conter e-mails e telefones disponíveis bem como quaisquer outros meios julgados necessários.

7 ARMAZENAMENTO DE DOCUMENTOS E EVIDÊNCIAS

Todas as **evidências relevantes coletadas** durante o tratamento de um incidente de segurança (logs de auditoria, dados de e-mail, alertas de segurança, imagens de discos virtuais, sistemas comprometidos, arquivos de malware etc.) devem ser armazenadas, tomando-se o cuidado de **registrar todas as ações adotadas**

(informações repassadas pelo usuário, ações tomadas pelo time de resposta, informações importantes dos envolvidos, resultados da investigação etc.), de modo que esses registros e evidências possam permitir a análise por parte de pessoas autorizadas ou mesmo por autoridades.

Os usuários devem ser orientados, nesse momento, a não fazer quaisquer alterações ou modificações nos sistemas comprometidos durante a fase de tratamento do incidente, ou até que o time de resposta autorize.

Saiba mais: Existem várias ferramentas de registro e acompanhamento de *tickets* que, além de permitirem o registro, também documentam todo o processo. Muito úteis no contexto do plano de tratamento de incidentes.

Uma dessas ferramentas é a *Request Tracker*, e para saber um pouco mais sobre ela, é só acessar o link abaixo:

<<https://bestpractical.com/request-tracker>>.

8 CHECKLISTS

Nessa etapa da elaboração do plano, faremos *checklists* diferentes de acordo com a prioridade do incidente (alta, média e baixa) discriminando a Ação e o Responsável por ela. Os quadros a seguir servirão para orientar quanto aos procedimentos e aos passos para a resolução dos incidentes e podem ser ajustados de acordo com as características de cada incidente. O resultado será semelhante ao do Quadro “Modelo de checklist”, guardadas as peculiaridades de cada cenário.

Ação		Responsável
Ações comuns		
1	Procedimento para tratamento de notificação de incidente: • Reporte deve ser recebido via e-mail ou telefone; • Todos os detalhes precisam ser registrados, incluindo informações de contato, e o ticket deve ser atribuído para um membro da equipe de resposta.	Equipe de resposta a incidente.
2	Revisar detalhes e atribuir prioridade: • A equipe de resposta precisa revisar os dados iniciais da notificação de incidente para determinar a criticidade e deve atribuir uma prioridade para o caso.	Equipe de resposta a incidente.
Incidentes de baixa prioridade		
3	Contenção ou remoção de ameaça: • O incidente deve ser atribuído a um membro da equipe de resposta a incidente e deve ser tratado com uma solução já mapeada; • O membro responsável deve seguir a orientação descrita em roteiros já mapeados; • As ações podem conter a remoção de vírus, reset de conta de usuário ou ainda o contato direto com o usuário impactado; • Se um computador contiver um vírus de baixo impacto, o dispositivo deve ser desconectado da rede para prevenir a propagação. Outros computadores devem ser analisados para a verificação de comprometimento.	Equipe de resposta a incidente.
4	Recuperação/restauração dos sistemas afetados: • Uma vez que a causa do incidente foi solucionada, o computador ou a conta de usuário deve ser recuperada; • Em eventos nos quais há comprometimento de sistemas, como numa infecção de vírus ou outra vulnerabilidade, o sistema operacional deve ser reinstalado para remover todos os traços da infecção. Após esse processo, a máquina pode ser reconectada à rede.	Equipe de resposta a incidente.

5	Documentação dos resultados: • Toda a investigação e as ações de recuperação precisam ser registradas no sistema RT; • Todos os detalhes relacionados a como o incidente foi resolvido devem ser anotados.	Equipe de resposta a incidente.
Ações comuns a Incidentes de alta e média prioridade		
6	Investigação Inicial: O comitê de segurança precisa revisar um incidente antes de este ser considerado médio ou alto a fim de validar as informações e definir quais são os passos para iniciar a investigação. Os seguintes fatores precisam ser considerados ao elevar a prioridade de um incidente para alta : • Dados pessoais ou privados foram comprometidos? • O impacto é visivelmente público? • O incidente pode impactar negativamente a reputação da organização, de colaboradores ou parceiros?	Comitê de segurança e risco.
Incidentes de média prioridade		
7	Contenção ou remoção de ameaça: • Os incidentes devem ser atribuídos a um membro do comitê de segurança que pode acionar qualquer outro funcionário, caso necessário; • O comitê precisa determinar se algum computador será confiscado até que a investigação seja realizada. Em algumas circunstâncias, o computador precisa ser desligado da rede até que se tenha um parecer favorável ao restabelecimento pela equipe técnica; • Todos os vírus, material impróprio ou outras causas de um incidente devem ser removidos durante a contenção para prevenir a propagação ou o comprometimento de outros sistemas.	Comitê de segurança e risco.

8	Remediar vulnerabilidades identificadas: • A investigação de um incidente pode revelar fraquezas ou vulnerabilidades nos processos de controle de segurança; • O comitê deve identificar, documentar e tomar ação para remediar as fraquezas e as vulnerabilidades implementando ou improvisando controles para prevenir a recorrência do mesmo evento; • A remediação pode se estender para a análise de violações a políticas de segurança, e nesses casos o comitê deve prover a conscientização ao usuário envolvido.	Comitê de segurança e risco.
9	Recuperação/restauração dos sistemas afetados: • Uma vez que a causa do incidente foi solucionada, o computador ou a conta de usuário deve ser recuperada; • O objetivo dessa recuperação é restabelecer os sistemas afetados de forma a evitar futuros incidentes semelhantes; • O comitê definirá se o sistema operacional deve ser reinstalado ou se um backup deve ser disponibilizado para permitir a recuperação; • Uma vez que isso ocorra, o sistema pode ser reconectado à rede, para retorno a suas atividades normais.	Equipe de resposta a incidente.
Condução de revisão e relatório pós-Incidente		
	• O comitê deverá rever a documentação e as evidências coletadas para determinar a causa raiz além de prover recomendações para prevenir a recorrência desse incidente. • Recomendações levantadas devem ser entregues em relatório pós-incidente para a diretoria. • O comitê deve informar os usuários impactados diretamente e os que reportaram problema inicial.	Comitê de segurança e risco.
Incidentes de alta prioridade		

10	Aclonamento do time de resposta: Dado o tamanho de um incidente de alta prioridade, a diretoria será responsável por acionar e coordenar os trabalhos dos especialistas necessários. Isso permitirá a coordenação centralizada das ações para resposta ao incidente com o intuito de evitar impacto negativo à instituição. A comunicação entre os envolvidos é fundamental para permitir a rápida resposta. A força tarefa pode ser dividida em três frentes: Investigação: Identificar a causa, motivação, usuários envolvidos e o dano causado pelo incidente. Contenção: Implementação de ações de monitoração e de controles de correção para reduzir o impacto durante um incidente. Restauração: Recuperação dos sistemas impactados ou ativação de plano de recuperação de desastres para restaurar os serviços para um estado seguro.	Diretoria.
11	Designar um coordenador de comunicação: A diretoria designará um coordenador de comunicação, para garantir eficácia e eficiência na comunicação com os usuários impactados e todos os outros envolvidos no incidente.	Diretoria.
12	Notificar envolvidos relevantes: Em eventos de alta prioridade, o coordenador de comunicação nomeado trabalhará com a diretoria para determinar quem precisa ser notificado sobre o incidente: • O mantenedor da instituição; • Funcionários e clientes; • Agências do governo; • Empresas parceiras; • Comunidade.	Coordenador de comunicação.
13	Condução de revisão e relatório pós-Incidente: • A diretoria deverá conduzir um processo formal de revisão do ocorrido apresentando uma breve discussão a respeito da causa raiz do incidente, provendo feedback sobre a resposta dada para a resolução do problema e sobre as recomendações de melhoria.	Diretoria.
14	Revisão dos resultados: • A diretoria deve promover ações de melhoria para que novos incidentes sejam evitados; • A diretoria deve avaliar todo o processo de tratamento em busca do aperfeiçoamento das ações tomadas para contenção e erradicação do incidente.	Diretoria.

Quadro 1 – Modelo de checklist
 Fonte: Elaborado pelo autor (2021)

Esses *checklists* devem ser alvo de constantes atualizações e melhorias, de modo que acompanhem as melhores formas de erradicação e contenção de incidentes que vão sendo aplicadas.

9 FLUXO BÁSICO PARA TRATAMENTO DE INCIDENTES

Por fim, elabora-se o fluxo básico para tratamento de incidentes, um fluxograma que facilitará a leitura visual e orientará as equipes e os comitês durante o processo de tratamento de incidentes de segurança.

Ao final da elaboração do plano de tratamento de incidentes, o fluxograma ficará parecido com o da Figura “Modelo de fluxo de tratamento de incidentes”, em que podemos observar os principais “pontos de controle” que facilitam e orientam o tratamento do evento.

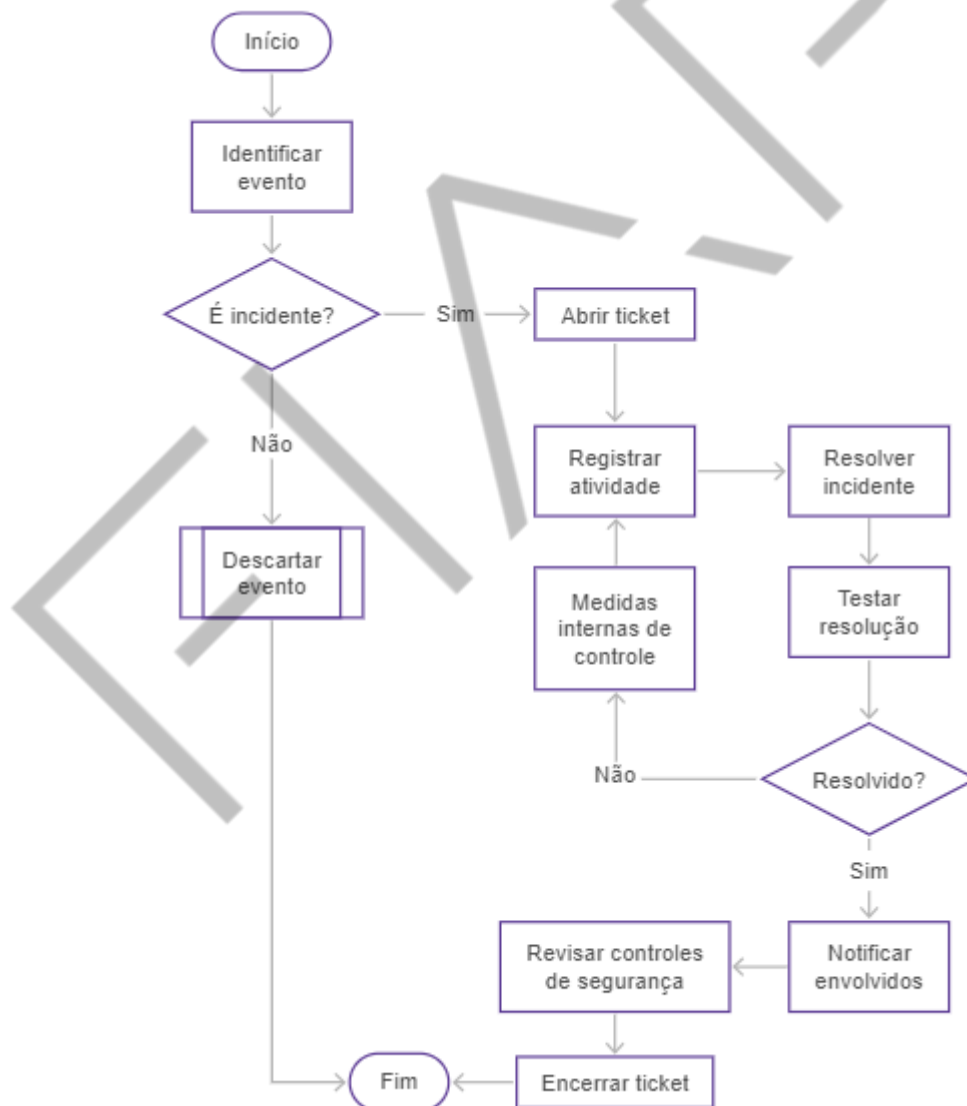


Figura 3 – Modelo de fluxo de tratamento de incidentes
Fonte: Elaborado pelo autor (2021)

CONCLUSÃO

Neste capítulo, podemos perceber como é trabalhoso elaborar um plano de tratamento de incidentes de segurança de TI em uma organização, não é mesmo? O levantamento de todos os dados, topologias, histórico de eventos, registros de incidentes, papéis e responsáveis, elaboração de checklists e fluxos de tratamento, entre outras ações, requer muita paciência e método.

O que devemos ter em mente quando elaboramos um plano de tratamento de incidentes é que o resultado prático deve ser o objetivo principal da adoção de uma metodologia desse tipo. A combinação de metodologias pode ser, inclusive, o melhor caminho a seguir, mesmo que prevaleça uma delas.

O importante, no final das contas, é sobretudo a correção tempestiva e adequada do incidente, restabelecendo os serviços e sistemas, objetivo esse que se torna possível pela adoção de um passo a passo previamente estudado e definido, que levou em consideração as especificidades do cenário, a experiência e o entrosamento das equipes, culminando no fortalecimento da instituição como um todo, resultando num diferencial competitivo importante no futuro.

REFERÊNCIAS

CERON, J. et al. **O processo de tratamento de incidentes de segurança da UFRGS**. 2009. Disponível em: <<https://www.lume.ufrgs.br/bitstream/handle/10183/16096/000696922.pdf?sequence=1>>. Acesso em: 13 jun. 2024.

CERT.br. **Cartilha de Segurança para Internet**. 2002. Disponível em: <<http://www.cartilha.cert.br>>. Acesso em: 13 jun. 2024.

ENISA. **Good Practice Guide for Incident Management**. 2010 Disponível em: <<https://www.enisa.europa.eu/publications/good-practice-guide-for-incident-management>>. Acesso em: 13 jun. 2024.

ISACA. **Cobit 5 Certificates**. Disponível em: <<https://www.isaca.org/credentialing/cobit>>. Acesso em: 13 jun. 2024.

ISO. **IEC 27035 – 1:2016 – Principles of Incident Management**. 2016. Disponível em: <[ISO/IEC 27035-1:2023 - Information technology — Information security incident management — Part 1: Principles and process](https://www.iso.org/standard/55822.html)>. Acesso em: 13 jun. 2024.

ITIL. **IT Service Management**. Disponível em: <<https://www.axelos.com/best-practice-solutions/itil>>. Acesso em: 13 jun. 2024.

PINTO, R. **A implantação de uma equipe de resposta a incidentes de segurança em uma instituição de ensino**. Especialização (Pós-graduação Lato Sensu em Rede de Computadores com Ênfase em Segurança). Centro Universitário de Brasília, Instituto CEUB de Pesquisa e Desenvolvimento – ICPD. Brasília, 2017. Disponível em: <<https://repositorio.uniceub.br/jspui/bitstream/235/12407/1/51600262.pdf>>. Acesso em: 13 jun. 2024.